

Data Privacy: Analysis of Reproductive Health Data Risk for Texas-Based Flo Users Under Texas SB 8

1 INTRODUCTION

In September 2021, Texas enacted Senate Bill 8, specifically the 2021 “The Texas Heartbeat Act”, banning abortion after approximately six weeks of pregnancy, then authorizing any private citizen to sue anyone who aids or abets a prohibited procedure for a minimum of \$10,000 in damages (Congressional Research Service, 2021). At roughly the same time, millions of Texas women were using Flo, a period and ovulation tracking application with over 420 million users worldwide, to log their menstrual cycles, pregnancy symptoms, and reproductive health data. These two developments may not have a direct connection, but they interact in ways that existing law is ill-equipped to address.

This paper examines the data privacy problem created by the intersection of Flo Health's data collection practices and SB 8's private civil enforcement mechanism, with a geographic focus on Texas from 2021 to the present. The problem is specific: Flo collects granular reproductive health data, has a documented history of sharing that data with third parties despite promising not to (Federal Trade Commission, 2021a), and explicitly acknowledges in its own policies that it will disclose user information in response to subpoenas and civil legal process (Flo Health, 2024b). SB 8 allows private litigants with financial incentives to obtain exactly this kind of information. The regulatory frameworks that might be expected to prevent this, including HIPAA, the GDPR, and FTC enforcement, each contain structural gaps that leave Texas users exposed.

Flo's UK incorporation and GDPR compliance are frequently cited as evidence that user data is protected to the highest global standard (Flo Health, 2024a). This paper argues otherwise.

Flo's consent model and commercial data-sharing ecosystem, combined with Texas's private civil enforcement mechanism (SB 8), creates a surveillance pathway that existing federal protections cannot adequately address. The same GDPR provision Flo relies on to resist disclosure may also authorize compliance with a valid civil subpoena. This is because data transferred to US-based servers falls under US jurisdiction regardless of where the controller is registered, and the data broker ecosystem downstream of Flo operates largely outside any privacy framework at all.

2 STAKEHOLDERS

The central data subject relationship in this problem is between Texas women of reproductive age and Flo Health, a UK-registered (recently) company that operates as the data controller for all user information collected through the app (Flo Health, 2024a). Users voluntarily submit highly sensitive reproductive health data, including menstrual cycle dates, pregnancy status, and symptoms, in exchange for predictive health insights. This relationship is unequal, as the users bear the legal risks of disclosure while Flo captures the commercial value of the data.

Flo is the primary owner of this problem. The company designs the consent model, determines what third parties receive data, and sets the policies under which it responds to the legal process. The FTC found that Flo shared user health data with advertising/analytics partners including Facebook and Google, despite promising users it would not (Federal Trade Commission, 2021a; Federal Trade Commission, 2021c). A 2025 jury verdict further confirmed that Meta received and used that data in violation of California privacy law (Alder, 2025). In addition, third-party vendors/data brokers who receive or purchase Flo-derived data are the

purchasers and intermediaries in this ecosystem, where they are largely unregulated under federal law (Jones & Kaminski, 2020).

In this case, regulatory authority is fragmented. The FTC holds limited jurisdiction over app data practices under its unfair and deceptive practices mandate, but has no authority over data brokers and cannot address SB 8's civil enforcement structure directly (Federal Trade Commission, 2021b). HIPAA does not cover consumer health applications (Alder, 2023). Private litigants are authorized under SB 8 to sue anyone who aids or abets an abortion (including the person who undergoes the abortion). They also represent an enforcement class with direct financial incentives to access reproductive data (Congressional Research Service, 2021). The harms from this arrangement are not evenly distributed. Stakeholders like low-income Texas women, who are least likely to have the digital literacy to use privacy tools or the financial means to seek care discreetly out of state, now bear a disproportionate share of the legal and personal risk of reproductive healthcare.

3 TECHNOLOGIES

Devices

The primary device in this problem is the smartphone, specifically the Flo mobile application running on IOS and Android platforms. The app's architecture depends heavily on third-party software development kits, or SDKs, which are pre-built code packages that developers embed directly into an application to enable analytics, advertising, and tracking functions. Flo integrated SDKs from Facebook, Google, Flurry, and AppsFlyer, among others (Federal Trade Commission, 2021a). These SDKs operate largely invisibly to users; when a user logs a symptom or marks a missed period, the SDK can simultaneously transmit that interaction as an App Event to its parent company's servers. Flo shapes how these devices function by

choosing which SDKs to embed and what data they collect, but once data leaves Flo's servers and enters a third-party platform, Flo's control over it ends.

Policies

Three overlapping policy frameworks shape this problem, and their gaps are as important as their requirements. First, the GDPR applies to Flo because Flo Health UK Limited is registered as the data controller in the United Kingdom. The GDPR classifies health and reproductive data as special category data requiring heightened protection, and Flo markets this coverage as a guarantee of user safety regardless of geography (Flo Health, 2024a). Jones and Kaminski (2020) caution, however, that the GDPR is not primarily a consent-based regime; it is a corporate compliance framework, and its protections follow the data only so far as the controller's obligations extend. Once data is transferred to US-based processors, it enters US legal jurisdiction and becomes reachable by US courts. While the European Commission adopted an adequacy decision for the EU-U.S. Data Privacy Framework in 2023, that framework governs the lawfulness of data transfers and does not protect data held on US servers from civil subpoenas issued by US courts (European Commission, 2023).

Second, unlike conventional abortion regulations enforced by state officials, SB 8 deputizes private citizens to bring civil suits against anyone who aids or abets a prohibited abortion, with a statutory minimum damages award of \$10,000 per successful claim (Congressional Research Service, 2021). This design deliberately removes state actors from the enforcement chain, which avoids the pre-enforcement legal challenges that typically restrict unconstitutional statutes.

Data

The data Flo collects is the main issue of this entire problem. Through normal app use, Flo gathers menstrual cycle dates, pregnancy status, symptoms, mood, sexual activity, and due date information, all of which users input voluntarily in exchange for predictive health insights (Flo Health, 2024a). The app also infers health information from behavioral patterns, and can import additional data from wearable devices through Apple HealthKit and Google Health (Flo Health, 2024b). The FTC complaint documented that Flo converted this logged information into App Events with titles explicitly referencing pregnancy and sent them to advertising/analytics platforms despite promising users those platforms would receive only non-personally identifiable information (Federal Trade Commission, 2021a). This data enters a commercial pipeline that Flo does not control. Data brokers aggregate behavioral and health-adjacent data from multiple sources and resell it with few legal restrictions under current federal law (Jones & Kaminski, 2020). A civil litigant under SB 8 need not subpoena Flo directly but can purchase a dataset from a broker that has already aggregated the relevant information, or subpoena one of Flo's third-party SDK partners, none of whom are bound by Flo's privacy commitments.

Taken together, these three technology layers place decision-making power in Flo and its commercial partners while distributing legal risk exclusively to users. Flo designs the devices, negotiates the policies, and benefits from the data. Texas women of reproductive age, particularly those with lower incomes and less access to privacy tools, have no actual ability to influence any of these layers, thus, holding all of the legal consequences and risks.

4 STAKES

The core problem with Flo's data practices in Texas is not simply that sensitive health data exists but the vulnerability that it causes. Flo's predictions improve the more consistently and granularly a user logs: missed periods, pregnancy symptoms, cycle irregularities. That same

granularity, however, produces a timestamped record of reproductive activity that can infer a pregnancy and its outcome. The data that makes Flo useful is precisely the data that makes it dangerous. Users cannot have both accurate predictions and legal safety.

Separately, SB 8 plaintiffs have already used the law's pre-suit deposition mechanism to seek records from abortion funds, demonstrating that civil litigants are actively pursuing discovery to identify those who aided or abetted abortions (Congressional Research Service, 2021). In addition, awareness that period-tracking data could be subpoenaed or purchased produces a chilling effect on reproductive healthcare-seeking behavior, which is itself a significant harm on healthcare rights. In addition, these legal risks are not evenly distributed. Low-income Texas women, who are the least able to afford legal counsel, also are held to the exposure from a surveillance infrastructure that generates profit for Flo and its data partners while concentrating the risk in the users' bodies.

5 SOLUTIONS

Flo's Internal Responses

Following the FTC action, Flo introduced Anonymous Mode, a feature that removes the link between a user's identity and their health data by creating a separate account without name, email address, or device identifiers (Flo Health, 2024a). Flo's data request policy states that in the event of a legally valid subpoena, it cannot identify Anonymous Mode users and therefore cannot fulfill information requests for them (Flo Health, 2024a). This is a substantive technical protection, however its limitations are significant. Switching to Anonymous Mode requires users to already understand the legal risk they face, take action, and accept the deletion of their existing account history. It is a protection that rewards digital literacy and disproportionately fails the low-income users identified in the stakeholders section as bearing the greatest risk.

Anonymous Mode also does nothing about data already transmitted to third-party SDK partners before a user switches modes.

FTC Enforcement

The FTC's 2021 consent decree required Flo to obtain affirmative user consent before sharing health data with third parties and to instruct those third parties to delete previously received data (Federal Trade Commission, 2021b; Federal Trade Commission, 2021c). This was a meaningful intervention against Flo's historical data-sharing practices. Its limits, however, are structural. The FTC's authority under its unfair and deceptive practices mandate applies to Flo's direct conduct, not to the data broker ecosystem, and not to civil discovery requests issued by private SB 8 litigants. The decree addresses past misconduct without closing the legal process gap that is central to this paper's argument. Flo's own privacy policy still explicitly states it will disclose user data in response to subpoenas, court orders, or legal processes as required by applicable law, with no exception for reproductive health data or for SB 8's private civil litigants (Flo Health, 2024b).

The GDPR's Limits in US Legal Context

Flo markets its UK incorporation and GDPR compliance as a meaningful privacy guarantee for users worldwide (Flo Health, 2024a). This framing is misleading in the specific context of US civil discovery. The GDPR does govern Flo as a data controller, and health data qualifies as special category data requiring heightened protection. While the European Commission adopted an adequacy decision for the EU-US Data Privacy Framework in 2023, that framework governs the lawfulness of data transfers and does not protect data held on US servers from civil subpoenas issued by US courts (European Commission, 2023). As Schwartz and Peifer (2017) establish, data transferred from UK or EU servers to US-based processors falls

under US jurisdiction once it crosses that boundary. More critically, GDPR Article 49(1)(e) permits data transfers necessary for the establishment, exercise, or defense of legal claims (European Parliament & Council of the European Union, 2016). This is the provision Flo's own policy cites as a basis for responding to legal process, and it does not distinguish between legitimate litigation and SB 8's private civil enforcement mechanism. The GDPR, in other words, may not block a valid subpoena. It may actually authorize compliance with one.

Regulatory and Legislative Gaps

At the federal level, the proposed American Data Privacy and Protection Act stalled in Congress without passing, leaving consumer health apps outside the scope of any comprehensive federal data privacy framework. HIPAA does not apply to Flo, as established in the technologies section, and research suggests many users mistakenly assume it does (Alder, 2023). Texas enacted the Texas Data Privacy and Security Act in 2024, its first comprehensive consumer data privacy law, but the TDPSA contains no private right of action and enforcement rests exclusively with the Texas Attorney General. It does not address civil discovery requests under SB 8 and does not close the specific gap this paper identifies. The result is a regulatory gap specific to Texas users, where the only applicable federal oversight is the FTC consent decree, which does not address civil discovery, and the most consequential applicable state law is SB 8, which actively incentivizes the use of reproductive data against the people who generated it.

Why the Problem Persists

This problem persists because the incentive structures of all powerful parties point away from fixing it. Flo's business model depends on granular data collection. Data brokers profit from aggregating and reselling health-adjacent data with minimal regulation. Texas legislators designed SB 8 specifically to leverage private data networks by removing state actors from the

enforcement chain, making judicial challenges difficult (Congressional Research Service, 2021). Federal legislative gridlock has prevented the passage of comprehensive data privacy law for years. The GDPR, despite its reputation as the world's strictest privacy framework, contains the very derogation that could authorize the disclosure it is presumed to prevent (European Parliament & Council of the European Union, 2016). No single actor has both the incentive and the authority to close all of these gaps simultaneously, and until that changes, Texas women using Flo bear the consequences of a system designed to benefit everyone but them.

6 CONCLUSION

Flo Health collects some of the most sensitive data a person can generate, and it does so by design. The app's utility depends on granular, consistent logging of reproductive activity, and that same granularity produces a legal liability for Texas women that no existing regulatory framework adequately addresses. The FTC established that Flo shared this data despite promising not to. Flo's own policies confirm it will disclose user information in response to a valid legal request. The GDPR, which Flo markets as the world's strictest privacy protection, contains legal claims that may authorize rather than block compliance with a civil subpoena. Anonymous Mode offers protection that is narrow, available only to digitally literate users.

The unequal distribution of risk and benefits of this problem has created a cause for concern. The commercial benefits of Flo's data ecosystem flows to the company, its analytics partners, and data brokers. The legal risks flow downward, concentrating in the bodies of low-income Texas women who are the least positioned to protect themselves through privacy tools, legal counsel, or out-of-state travel. This is the predictable result of a system in which data collection is profitable, data protection is fragmented, and civil enforcement is financially incentivized.

Meaningful change requires action from those with direct power over the problem. Flo could implement strict data minimization. Federal legislators could pass comprehensive health data privacy law that covers consumer applications and limits civil discovery into reproductive health records. The FTC could expand its interpretation of unfair practices to address the civil discovery gap explicitly. Until any of that happens, Texas women using Flo are left navigating a surveillance pathway that existing law was not designed to close.

Federal Trade Commission. (2021a, January 13). Developer of popular women's fertility-tracking app settles FTC allegations that it misled consumers about the disclosure of their health data [Press release].

<https://www.ftc.gov/news-events/news/press-releases/2021/01/developer-popular-womens-fertility-tracking-app-settles-ftc-allegations-it-misled-consumers-about>

Federal Trade Commission. (2021b, June 22). FTC finalizes order with Flo Health, a fertility-tracking app that shared sensitive health data with Facebook, Google, and others [Press release].

<https://www.ftc.gov/news-events/news/press-releases/2021/06/ftc-finalizes-order-flo-health-fertility-tracking-app-shared-sensitive-health-data-facebook-google>

Federal Trade Commission. (2021c). In the matter of Flo Health, Inc.: Decision and order (File No. 192 3133).

https://www.ftc.gov/system/files/documents/cases/192_3133_flo_health_decision_and_order.pdf

Schwartz, P. M., & Peifer, Karl-Nikolaus. (2017). Transatlantic data privacy law.

Georgetown Law Journal, 106(1), 115-180.

Jones, M. L., & Kaminski, M. E. (2020). An American's guide to the GDPR. Denver Law Review, 98(1), 93–128.

Congressional Research Service. (2021). The Texas Heartbeat Act (S.B. 8), Whole Woman's Health v. Jackson, and United States v. Texas: Frequently asked questions (LSB10651).

<https://www.congress.gov/crs-product/LSB10651>

Flo Health. (2024a). Privacy policy. <https://flo.health/privacy-policy>

Flo Health. (2024b). Consumer health data privacy notice.

<https://flo.health/consumer-health-data-privacy-notice>

Flo Health. (2024c). Supplemental Flo US state privacy notice.

<https://flo.health/supplemental-flo-us-state-privacy-notice>

Alder, S. (2023, July 26). Americans mistakenly believe health apps are covered by HIPAA. The HIPAA Journal. <https://www.hipaajournal.com/americans-mistakenly-believe-health-app-hipaa/>

Alder, S. (2025, September 26). Jury finds Meta violated California privacy law by collecting Flo app users' sensitive data. The HIPAA Journal.

<https://www.hipaajournal.com/jury-trial-meta-flo-health-consumer-privacy/>

European Commission. (2023, July 10). Questions & answers: EU-US Data Privacy Framework.

https://ec.europa.eu/commission/presscorner/detail/en/qanda_23_3752

European Parliament & Council of the European Union. (2016). Regulation (EU) 2016/679 of the European Parliament and of the Council (General Data Protection Regulation), Article 49:

Derogations for specific situations. Official Journal of the European Union.

<https://gdpr-info.eu/art-49-gdpr/>

H.R.8152 - 117th Congress (2021-2022): American Data Privacy and Protection Act. (2022, December 30). <https://www.congress.gov/bill/117th-congress/house-bill/8152>

European Commission. (2023, July 10). Questions & answers: EU-US Data Privacy Framework.

https://ec.europa.eu/commission/presscorner/detail/en/qanda_23_3752